Analisi del rapporto sull'incidente

Riepilogo	Una stagista ha detto al reparto IT di non riuscire ad accedere al suo account. I log di accesso mostravano che l'account stava ancora leggendo record del database dei clienti, anche se lei era bloccata fuori. Quella mattina aveva ricevuto un'email che le chiedeva di accedere a un sito esterno con le credenziali aziendali per leggere un messaggio, quindi pensiamo che le sue credenziali siano state rubate con un attacco di phishing. Alcuni dipendenti hanno anche notato record di clienti mancanti o sbagliati, il che significa che l'attaccante non si è limitato a leggere i dati: una parte è stata cancellata o modificata. Identificare, Proteggere e Rilevare descrivono ciò che l'azienda cambia dopo questo incidente per essere più preparata. Rispondere e Ripristinare descrivono come si gestisce l'incidente vero e proprio.
Governare	Aggiungerei una policy scritta sugli accessi che dica che una password da sola non basta mai per arrivare ai dati dei clienti. Dovrebbe anche indicare chi è responsabile di rivedere chi ha accesso al database e chi organizza ogni anno la formazione sul phishing, così questi compiti non dipendono dalla memoria di qualcuno.
Identificare	Il team dell'incidente ha esaminato i sistemi, i dispositivi e le policy di accesso coinvolti. La lacuna era che bastavano un nome utente e una password per raggiungere il database dei clienti, e che i dipendenti non erano formati a riconoscere un'email di phishing.
Proteggere	Nuove regole di autenticazione: autenticazione a più fattori (MFA), un limite di tre tentativi di accesso e una formazione per tutti i dipendenti su come proteggere le proprie credenziali. Verrà migliorata anche la configurazione del firewall e l'azienda investirà in un sistema di prevenzione delle intrusioni (IPS).
Rilevare	Uno strumento di log del firewall e un sistema di rilevamento delle intrusioni (IDS) monitoreranno il traffico in arrivo da internet, così i tentativi di accesso non autorizzato verranno notati prima.
Rispondere	L'account della stagista è stato disattivato. Stagisti e dipendenti hanno ricevuto una formazione su come proteggere le credenziali di accesso. La direzione è stata informata e scriverà ai clienti coinvolti e contatterà le forze dell'ordine e gli altri enti previsti dalle leggi

	locali.
Ripristinare	I dati cancellati verranno ripristinati dal backup completo della notte scorsa. Quello che è stato inserito o modificato questa mattina non è nel backup, quindi al personale è stato detto che dovrà reinserirlo dopo il ripristino.
Riflessioni / Note	Una password rubata non dovrebbe mai bastare per entrare nei dati dei clienti. Il backup è ciò che ha limitato il danno in questo caso, quindi deve essere recente e testato. Quello che ho imparato qui rientra in ogni funzione sopra, a partire da Governare.